

THREAT INTELLIGENCE REPORT

APT29 — Cozy Bear

Nation-State Threat Actor Profile | TLP: WHITE | Self-Initiated Portfolio Project

Vishwas M H | B.Tech CSE | Independent Threat Intelligence Research

All sources are publicly available. Researched and compiled independently by Vishwas M H, B.Tech CSE.

Report Date: June 2025 | Classification: TLP:WHITE — Unrestricted Distribution

1. Executive Summary

In this independent research project, I profiled APT29 — also known as Cozy Bear —, The Dukes, Midnight Blizzard (Microsoft), and YTTRIUM, is a sophisticated Advanced Persistent Threat actor attributed with high confidence to Russia's Foreign Intelligence Service (SVR — Sluzhba Vneshney Razvedki). The group has been conducting cyber espionage operations since at least 2008 and represents one of the most technically capable and operationally disciplined nation-state threat actors currently active.

APT29 is distinguished from other threat actors by its extreme patience (operations spanning months to years), rigorous operational security, preference for living-off-the-land techniques, and sophisticated use of trusted cloud services (Dropbox, OneDrive, Google Drive) as command and control infrastructure to blend with legitimate traffic.

CURRENT THREAT LEVEL: HIGH. APT29 operations have significantly increased since 2022. CISA, NCSC, and AIVD Netherlands have issued joint advisories warning of APT29 targeting government, defence, and technology sectors globally including EU member states.

Threat Actor Name	APT29 / Cozy Bear / The Dukes / Midnight Blizzard
Attribution (Confidence)	Russian Foreign Intelligence Service (SVR) — HIGH CONFIDENCE
Active Since	2008 (first documented operations)
Primary Motivation	Espionage — Intelligence collection for Russian state interests
Target Sectors	Government, Defence, Think Tanks, Healthcare, Technology, Energy
Geographic Targets	USA, EU (including Ireland), NATO members, Ukraine, former Soviet states
Sophistication Level	Very High — Custom tooling, supply chain attacks, cloud-native C2
MITRE ATT&CK ID	G0016
Notable Operations	SolarWinds (2020), DNC Hack (2016), COVID-19 vaccine research theft (2020)

2. Tactics, Techniques and Procedures (TTPs)

APT29 operations are mapped below to the MITRE ATT&CK Enterprise framework. The group's TTP profile is characterised by a strong preference for stealth over speed — they prioritise remaining undetected for months or years over rapid exploitation.

2.1 Initial Access

Technique ID	Technique	Description
T1566.002	Spearphishing Link	Highly targeted spearphishing emails to specific individuals, often mimicking legitimate organisations (NATO, think tanks). Emails are exceptionally well-researched using OSINT on targets.
T1195.002	Supply Chain Compromise	The SolarWinds attack (2020) is the defining example — APT29 compromised the SolarWinds Orion build system to deliver malicious updates to 18,000+ customers including US government agencies.
T1078	Valid Accounts	APT29 extensively uses stolen credentials acquired through phishing or dark web purchases to authenticate to legitimate services, avoiding malware-based detection entirely.
T1190	Exploit Public-Facing Applications	Exploitation of vulnerabilities in internet-facing applications (VPN gateways, Exchange servers). CVE-2021-26855 (Exchange ProxyLogon) was used in attributed campaigns.

2.2 Execution & Persistence

- T1059.001 — PowerShell: APT29 uses PowerShell extensively for fileless execution. Custom tools including SUNBURST backdoor were executed through PowerShell to avoid file-based detection.
- T1053.005 — Scheduled Tasks: Persistence maintained through Windows Scheduled Tasks, often mimicking legitimate system tasks with similar names (e.g., 'Windows Defender Update').
- T1547.001 — Registry Run Keys: Backdoors placed in HKCU\Software\Microsoft\Windows\CurrentVersion\Run for persistence across reboots.
- T1078.002 — Domain Accounts: After initial access, APT29 establishes persistence using compromised domain accounts — much harder to detect than malware-based persistence.

2.3 Defense Evasion — Signature Techniques

- T1036.005 — Match Legitimate Name or Location: APT29 names malicious files and directories to exactly match legitimate Windows system files and locations to confuse analysts.
- T1027 — Obfuscated Files or Information: Custom packer and obfuscation routines applied to all tooling. SUNBURST used a 12-day dormancy period after infection before activating — specifically to evade sandbox analysis tools that time-limit analysis.
- T1102 — Web Service as C2: APT29's most distinctive evasion technique — using legitimate cloud services (Dropbox, OneDrive, Google Drive, Slack) as command and control channels. This traffic is

encrypted by the service, blends with legitimate corporate traffic, and cannot be blocked without impacting business operations.

- T1070 — Indicator Removal: APT29 actively cleans logs, removes tools, and eliminates evidence of presence. Multiple groups of analysts have lost forensic evidence to APT29 counter-forensics activities.

2.4 Credential Access & Lateral Movement

- T1003.001 — LSASS Memory Dump: Credential dumping from Windows LSASS process using custom memory reading tools to avoid triggering standard AV/EDR signatures for Mimikatz.
- T1550.002 — Pass the Hash: Harvested NTLM hashes used for lateral movement without knowing plaintext passwords.
- T1021.001 — Remote Desktop Protocol: APT29 uses RDP extensively for lateral movement after acquiring valid credentials. RDP sessions appear as legitimate administrator activity.
- T1018 — Remote System Discovery: Systematic network discovery using built-in Windows commands (net view, ping, nslookup) to map the network and identify high-value targets.

2.5 Exfiltration

- T1048.002 — Exfiltration Over Alternative Protocol (Encrypted): Data exfiltrated over HTTPS to attacker-controlled infrastructure or legitimate cloud services. Traffic indistinguishable from normal HTTPS at network layer.
- T1030 — Data Transfer Size Limits: APT29 limits exfiltration to small quantities over extended periods to avoid triggering data loss prevention (DLP) tools based on volume thresholds.
- T1567.002 — Exfiltration to Cloud Storage: SUNBURST specifically exfiltrated data to cloud services including Dropbox and legitimate-looking attacker-controlled Azure tenants.

3. Notable Operations

3.1 SolarWinds Supply Chain Attack (2020)

The SolarWinds operation represents one of the most significant and sophisticated cyber intrusions ever publicly documented. APT29 compromised the build pipeline of SolarWinds Orion (IT management software used by 33,000+ organisations) and inserted a backdoor called SUNBURST into the legitimate software update mechanism.

- **Duration:** The compromise of SolarWinds' build environment occurred in October 2019. The malicious SUNBURST update was deployed in March 2020. Detection occurred in December 2020 — 14 months after initial compromise.
- **Scale:** Approximately 18,000 organisations downloaded the malicious update. APT29 selectively activated the backdoor in approximately 100 organisations deemed high-value targets.
- **Victims (confirmed):** US Treasury, US Departments of Homeland Security, State, Commerce, and Justice. Multiple EU government agencies. Major technology companies including Microsoft, Intel, Cisco.
- **Key innovation:** The 12-day dormancy period and use of legitimate SolarWinds infrastructure for initial C2 check-ins made the malware appear completely benign to automated analysis tools.

3.2 COVID-19 Vaccine Research Theft (2020)

A joint advisory from NCSC UK, CSE Canada, NSA, and CISA attributed a campaign targeting COVID-19 vaccine research organisations in 2020 to APT29. Targets included Oxford University, AstraZeneca, and multiple national health authorities.

- **Technique:** Spearphishing and exploitation of unpatched Citrix and VPN vulnerabilities (CVE-2019-19781, CVE-2018-13379).
- **Objective:** Intelligence collection on vaccine development progress — consistent with Russian state interest in competitive intelligence and undermining Western vaccine programs.
- **Ireland relevance:** The European Medicines Agency (EMA) was breached in December 2020. Documents related to COVID-19 vaccine regulatory submissions were accessed and subsequently leaked — attributed to Russian state-sponsored actors.

4. Indicators of Compromise (IOCs)

NOTE: All IOCs listed below are historical indicators from public threat intelligence reports. They are published for educational and detection rule creation purposes. Real-time IOC feeds should be sourced from MISP, AlienVault OTX, or commercial threat intelligence platforms.

4.1 Network Indicators

Known APT29 C2 infrastructure (historical — may be recycled):

Domain: avsvmcloud[.]com (SUNBURST primary C2 — sinkholed December 2020)

Domain: freescanonline[.]com (TEARDROP dropper staging)

Domain: deftsecurity[.]com (SUNBURST C2)

Domain: thedoccloud[.]com (SUNBURST C2)

IP: 13.59.205.66 (Cobalt Strike C2 — historical)

IP: 199.201.62.239 (Cobalt Strike beacon staging)

IP: 18.220.219.143 (TEARDROP C2)

4.2 File-Based Indicators

Hash (SHA256): 019085a76ba7126fff22770d71bd901c325fc68ac55aa743327984e89f4b0134 (SUNBURST DLL)

Hash (SHA256): ce77d116a074dab7a22a0fd4f2c1ab475f16eec42e1ded3c0b0aa8211fe858d6 (TEARDROP loader)

File Name: SolarWinds.Orion.Core.BusinessLayer.dll (SUNBURST infected version)

File Name: c:\windows\syswow64\netsetupsvc.dll (TEARDROP backdoor)

Registry Key: HKLM\SOFTWARE\Microsoft\Cryptography\MachineGuid (SUNBURST stores victim ID)

4.3 Behavioural Indicators

- PowerShell processes with Base64 encoded command lines launched from within SolarWinds Orion service context.
- Outbound HTTPS connections to subdomains of avsvmcloud[.]com (structure: [encoded_victim_hash].appsync-api.[region].avsvmcloud.com).
- New scheduled tasks with names matching legitimate Windows tasks but with slight variations (extra spaces, different capitalisation).
- LSASS memory reads by processes other than known security tools — potential credential dumping.
- Outbound connections to legitimate cloud services (Dropbox, OneDrive) from servers that have no business reason to access these services.

5. Defensive Recommendations

5.1 Detection Controls

- Enable comprehensive PowerShell logging (Script Block Logging, Module Logging, Transcription) across all endpoints.
- Implement UEBA (User and Entity Behaviour Analytics) to detect anomalous access patterns — particularly off-hours access, impossible travel, and unusual data access volumes.
- Monitor LSASS access by non-authorised processes — deploy Credential Guard on Windows 10/11 endpoints to protect LSASS memory.
- Establish DNS monitoring and alert on queries to newly registered domains (<30 days old) from internal servers.
- Implement network segmentation — servers with no business need to access internet should have egress filtered at firewall level.

5.2 Preventive Controls

- Supply chain security: Implement software bill of materials (SBOM) requirements for all third-party software. Verify integrity of software updates using hash validation.
- Zero Trust Architecture: Implement principle of least privilege and just-in-time access for all administrative accounts.
- MFA everywhere: APT29 extensively uses stolen credentials. MFA is the single highest-impact control against this threat actor.
- Patch management: APT29 exploits known vulnerabilities including those disclosed years prior. Critical patches within 72 hours is the minimum acceptable SLA.
- Email security: DMARC enforcement (p=reject), DKIM, and SPF reduce phishing effectiveness. Advanced email security platforms with sandboxing detect novel spearphishing.

5.3 Incident Response Considerations

APT29 actively conducts counter-forensics. If APT29 presence is suspected, engage specialist incident response immediately. Standard IR procedures may alert the adversary and cause evidence destruction.

- Assume credential compromise across the entire environment — not just the initially identified system.
- Preserve memory images before touching any suspected compromised host. APT29 malware may self-delete on reboot or upon detection.
- Engage law enforcement (NCSC Ireland, Garda National Cyber Crime Bureau) for nation-state intrusions.

6. Intelligence Sources

- MITRE ATT&CK — APT29 Group Profile: attack.mitre.org/groups/G0016/
- CISA Advisory AA21-148A: Exploiting Pulse Connect Secure Vulnerabilities — attributed to APT29
- Mandiant Report: UNC2452 / SUNBURST Analysis (December 2020)
- NCSC UK Advisory: APT29 targeting COVID-19 vaccine research (July 2020)
- Microsoft MSTIC: Midnight Blizzard (NOBELIUM) threat actor profile
- FireEye Blog: Highly Evasive Attacker Leverages SolarWinds Supply Chain (December 2020)
- Volexity Blog: Dark Halo Leverages SolarWinds Compromise (December 2020)

All sources used in this report are publicly available OSINT including MITRE ATT&CK, CISA advisories, and published threat intelligence reports. This report was independently researched and written by me as part of my cybersecurity career transition portfolio. TLP:WHITE — no distribution restrictions. — Vishwas M H, B.Tech CSE